BiT-128 公开数据等价私钥恢复：hint 通道的算子求逆

GLM-5.3 Max JY Liu

2026 年 10 月 19 日

摘要

BiT-128 是 NICCS 首轮征集的签名候选（编号 sign-02），属 BLISS 一族的双模高斯设计。本文报告一项仅使用公开数据的密钥恢复：输入为公钥与 400 万条普通签名，不借助侧信道、插桩或计时信息，我们精确恢复了秘密多项式 `s0` 的全部 768 个系数，并按验证等价关系补全 (e, b_0)，构造出通过未修改参考 C 验证器的等价签名密钥——对新鲜消息的伪造签名 20/20 被接受，四组阴性对照全部被拒绝。恢复的核心是一个此前未被描述的泄露通道：签名侧 hint 论证式中的掩码消去结构，使得公开的量化 hint 成为等价私钥未知量 $R = b_0 - e$ 的直接一阶观测；对该观测的确定性结构建立线性算子定律并求逆，即得 R。标签通道准确率 96.19%，在 4×10^6 签名规模上直接分类零错误。同一密钥经两条相互独立的路线（本文 hint 算子路线与 z_1 回归路线）恢复出逐字节一致的等价私钥。

Abstract. BiT-128 is a bimodal-Gaussian lattice signature candidate (submission sign-02 of the NICCS first round). We report a public-data-only key recovery: from the public key and 4 million ordinary signatures—no side channels, no instrumentation, no timing—we recover all 768 coefficients of the secret polynomial `s0` exactly, complete (e, b_0) up to verification equivalence, and forge signatures on fresh messages that pass the unmodified reference C verifier 20/20, while all four negative controls are rejected. The core of the attack is a previously undescribed leakage channel: in the signer's hint identity, fresh masking noise cancels, so the public quantized hint is a direct first-order observation of $R = b_0 - e$, the only unknown of the equivalent key. A linear operator law for the deterministic structure of this observation, once inverted, yields R.

1 对象、授权与结论边界

审计于 2026 年 9 月 20 日启动，在 BiT 提交方授权下针对其自有参考实现进行；攻击输入仅为公钥与公开签名，秘密密钥材料只在事后评分时使用。缺陷属设计层面——双模符号位的联合分布携带密钥信息，而方案的安全论证只覆盖了边缘分布的独立性（详见技术报告的证明评估一节，`paper/security_proof_assessment_v2.pdf`）。

先给结论的量化形态，避免歧义：

2 缺陷定位：联合分布对边缘分布

BiT-128 的签名响应使用共享的双模符号位（BLISS 式 bimodal 结构）：秘密扰动的符号选择在多个坐标间共享，验证方程按双模恒等式吸收符号。单个观察者从一条签名里看到的每个分量都是边缘分布意义下“正确”的；问题出在**联合**分布——共享符号位使 z_0 的取值与秘密之间建立了公开

项	结果
输入	公钥 + 4×10^6 条公开签名（普通消息流）
`s0`	768/768 系数精确，模 q 解在窗口约束下唯一
(e, b_0)	验证等价补全：公钥只确定 $R = b_0 - e$，任何满足约束的组合签名能力相同
伪造	新鲜消息，未修改参考验证器，20/20 接受
阴性对照	硬币标签臂、篡改 e、篡改签名、篡改 pk，四组全部拒绝
交叉验证	两条独立路线恢复同一把等价私钥（逐字节一致）；3×10^6 条签名经原始 C 验证器重验证零失败

可计算的弱相关。z_0 通道由此给出 96.19% 准确率的符号标签：不完美，但远高于一半，足以驱动后续线性估计。

这一缺陷形态与 Espitau 等人对 BLISS 的侧信道攻击 [EFGT17] 有本质区别：后者需要运行时泄露，本攻击完全被动、只读签名文本。

3 恢复路线

3.1 hint 通道：掩码在哪里消去

签名侧计算 hint 论证式

$$w_a \;=\; w - z_2 + b_0 \cdot c_{\text{signed}} \quad (\text{含行 } 0 \text{ 的} b \text{ 修正}),$$

其中的关键结构是：w 与 z_2 都含有新鲜掩码 y_2，在差 $w - w_a$ 中**相互抵消**。于是

$$w_a \;=\; \text{base} - (R * c_{\text{signed}}) + \cdots, \qquad R = b_0 - e,$$

与新鲜掩码无关；公开的量化 hint h 量化的是 $y_2 - (R * c_{\text{signed}}) - \cdots$。$y_2$ 是密度已知的新鲜噪声，R 是等价私钥的全部未知量——h 是 R 的直接一阶观测。这一消去结构是本攻击的核心观察，也是 BiT 的设计者未计入的泄露面。

3.2 算子定律

对带符号挑战的对齐统计量，其期望中的确定性结构是 R 的线性泛函。对齐组合学部分在 “挑战位置不重复” 的抽样模型下有精确期望，实际由 Monte-Carlo 校准为算子 F_{op}；接受条件化项没有解析模型，由实证界定——求逆后残差 $\sigma \approx 0.10$（4×10^6 签名）。估计方程的形态：

$$\big(M \cdot I + N \cdot F_{\text{op}}\big)\,\hat{R} \;=\; -\frac{\gamma_2}{s}\,\Phi \;-\; P_0 \cdot M \cdot \Big(1 - \frac{2m}{d}\Big) \cdot \mathbf{1}[i = 0],$$

标签尺度 s 逐行以整数聚类目标拟合。

需要说明两处近似及其代价。其一，解析 tent 核是 iid 位置近似，对角超出精确 $N\tau$ 达 $(\tau-1)/d = 11.3\%$；相对位置互斥的 Monte-Carlo 算子把 Frobenius 误差压到 10.9%。其二，接受条件化未建模，这是本路线明确的诚实边界，其影响由实证残差界定而非声称排除。

3.3 全解一致性修正

解出 $\hat{R}$ 后，公钥关系 $s_0 = A_0^{-1}(16\,b_1 + R)$ 给出修正入口。我们采用一个自设的验收准则（razor）：模 q 解线性系统得到候选修正，**仅当整个 768 维解全部落入** $\{-1, 0, 1\}$（违规计数 nbad $= 0$）才接受；搜索按单点 $\rightarrow$ 成对 $\rightarrow$ 三元阶段化推进。实际在 $N = 4 \times 10^6$ 时直接分类已零错误，修正器是纵深防御而非必需环节。

3.4 数据量阶梯

规模	直接分类准确率	说明
10^6（oracle 臂）	99.87%	单修正闭合
10^6（attack 臂）	99.09%	7 个 iid 跨界
4×10^6	100%	s_0 768/768 精确，无需修正

4 恢复程度的精确语义

哪些量是精确恢复、哪些是等价补全，需要严格区分。s_0 精确：与原钥完全一致，且经两条独立路线交叉验证。(e, b_0) 是等价补全：公钥只确定了 $R = b_0 - e$，任何满足 $\hat{e} \in \{-1, 0, 1\}$、$\hat{b}_0 = R + \hat{e} \in [-8, 8)$ 的组合具有相同签名能力；我们的补全在允许处一律取 $\hat{e} = 0$（26 个强制边界坐标）。验证器无法区分两种密钥的签名——等价的含义是验证等价（不可区分签名能力），不声称输出同分布。

5 与其它路线的关系

针对 BiT-128 的密钥恢复目前共有三条独立路线：本仓库的 hint 算子路线、z_1 回归路线，以及 ePrint 2026/2232 第 8 章的 SSD 去卷积路线。三者恢复同一密钥，机制各异；逐维度对比见 `paper/three_way_comparison.md`。本路线的独立价值在于 hint 通道的显式代数刻画（掩码消去恒等式）与算子求逆框架——它是通用恢复框架 umodel（本仓库顶层目录）的第一个已验证实例，在与 BiT 代数不同的循环环玩具实例上零改动完成了端到端恢复，对 CS-128 与 COMPASS-SIG-128 的适用性判定也是同一框架给出的（见对应目录的报告）。

6 下一步工作

按代价从小到大：

1. **接受条件化项的解析建模**。当前是整条路线唯一未建模的环节，实证残差 $\sigma \approx 0.10$。若能给出闭式或半经验修正，数据量需求有望从 4×10^6 显著下降（z_0 标签在 10^6 已 99%+，瓶颈在算子精度）。
2. **低数据量体制**。4×10^6 是 “直接零错误” 的充分条件而非必要条件；修正器 + 逐行标度拟合在 10^6 已能闭合（99.87%），系统性的数据量—精度曲线（$\sigma \propto N^{-1/2}$，实测拟合指数 -0.497）已在框架中建立，可用于外推更小 N 下的修正搜索代价。

3. **标签与 hint 通道的信息论最优融合**。两通道信息目前串行使用；联合似然的最优加权理论上还能压低阈值。

4. **向同族方案迁移**。凡签名侧存在 "差式中新鲜掩码消去" 结构的双模设计都可能暴露同类通道；umodel 的 SchemeSpec 声明式规范就是为这类迁移准备的（带符号挑战的矩算子已推导：$\mathbb{E}[C^{\mathsf{T}}C] = \tau I$ 精确成立，交叉项消失）。

7 复现指南

```
# 路线 A：仅凭本目录公开工件（数分钟，纯 CPU）
python3 code/run_pipeline.py --artifacts artifacts --out key_hat.bin
# 预期输出 sha256:
# 4191a44b4bf1e081175986302b0d30605bb86f827dbe02c80d90ef7f704d5a11

# 路线 B：从零复现（需要 BiT 参考实现与约 400 万条签名）
python3 code/hint_channel_fast.py <dump.bin> <nsig> <tag>   # 累加 Phi_R
python3 code/hint_perrow.py real sim3m                      # 闭合
./forge_all pk.bin key_hat.bin 20    # 伪造闭环（原始 C 签名器/验证器）

# 通用框架自测与演示
python3 ../umodel/selftest.py
python3 ../umodel/run_demos.py
```

秘密数据（真实密钥 `ground.bin`、`sk.bin`、签名 dump）不入库；`--score` 可选接受真值文件，仅用于事后准确率报告。八项交叉验证与全部带日期工件的清单见技术报告可复现性一节。

8 更正记录

我们早期的笔记曾声称 z_1 回归路线 "精度饱和于 65–69%、永不收敛"。该说法已撤回：饱和是早期统计量 $\psi(z) = \mathrm{sign}(z)/(1024 - |z|)$ 加符号阈值判决的伪象，对原始响应的普通加权最小二乘按 RMSE $\propto N^{-1/2}$ 收敛（RMSE 0.184 @ 2×10^5，经公钥修正后闭合）。如实记录于此，因为它说明了统计量构造对结论的敏感性——这一教训同样适用于 CS-128 与 COMPASS-SIG-128 的判定（见各自报告）。

参考文献

[1] L. Ducas, A. Durmus, T. Lepoint, V. Lyubashevsky. *Lattice Signatures and Bimodal Gaussians*. CRYPTO 2013（ePrint 2013/383）.

[2] V. Lyubashevsky. *Fiat–Shamir with Aborts*. ASIACRYPT 2009.

[3] T. Espitau, P.-A. Fouque, B. Gérard, M. Tibouchi. *Side-Channel Attacks on BLISS*. CCS 2017（ePrint 2017/505）——需要运行时泄露；本攻击不需要.

[4] Z. Xiong, M. Wang. *Design-Level Cryptanalysis of the ICCS NGCC Round-1 Public-Key Candidates*. ePrint 2026/2232（SSD 去卷积路线）.

[5] BiT 提交包，NICCS 2026 首轮（sign-02）.